

PENETRATION TESTING LAB DA-1

Lab Assessment 1 (L53+L54 slot)

Name – Nori Karthikey
Reg No - 22BCI0052

Q1) List the Nmap commands that leverage the 3-way handshake in the TCP ports.

- What is a TCP 3-way Handshake Protocol?**
- How does SYN Flood Attack work? How can this attack be prevented/mitigated?**

Answer

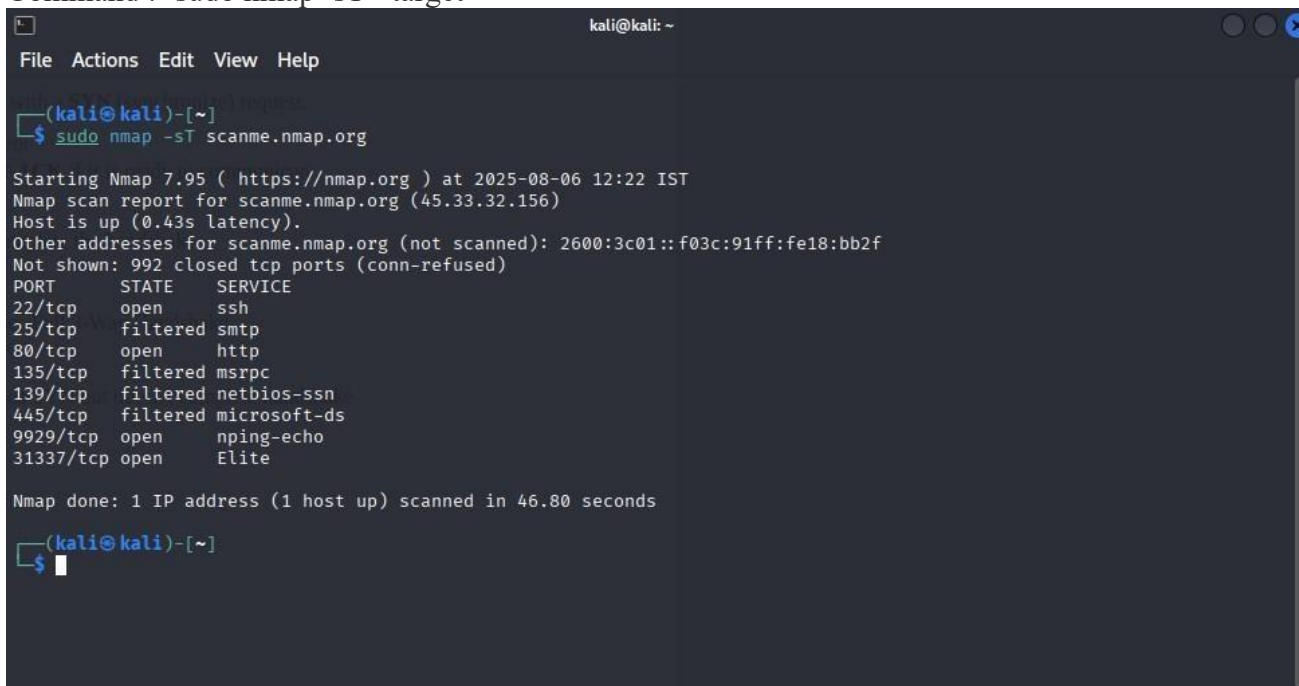
a) The TCP 3-way handshake is the process used to establish a reliable connection between two devices over a network.

Steps:

- 1. SYN:** Client → Server
Client initiates connection with a **SYN** (synchronize) request.
- 2. SYN-ACK:** Server → Client
Server responds with **SYN-ACK** if it is ready to communicate.
- 3. ACK:** Client → Server
Client sends an **ACK** to complete the handshake.

1) Full-Open (Connect) Scan Uses Full 3-Way Handshake

Command :- `sudo nmap -sT <target>`



```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ sudo nmap -sT scanme.nmap.org  
  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 12:22 IST  
Nmap scan report for scanme.nmap.org (45.33.32.156)  
Host is up (0.43s latency).  
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f  
Not shown: 992 closed tcp ports (conn-refused)  
PORT      STATE      SERVICE  
22/tcp    open      ssh  
25/tcp    filtered  smtp  
80/tcp    open      http  
135/tcp   filtered  msrpc  
139/tcp   filtered  netbios-ssn  
445/tcp   filtered  microsoft-ds  
9929/tcp  open      nping-echo  
31337/tcp open      Elite  
  
Nmap done: 1 IP address (1 host up) scanned in 46.80 seconds  
(kali@kali)-[~]  
$
```

2) Half-Open (SYN) Scan → Sends SYN but doesn't complete handshake

Command:- `sudo nmap -sS <target>`

```
kali@kali: ~  
File Actions Edit View Help  
└─$ sudo nmap -sT scanme.nmap.org  
[sudo] password for kali:  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 12:16 IST  
at leverage the 3-way handshake in the TCP ports.  
└─(kali@kali)-[~]  
└─$ sudo nmap -sS scanme.nmap.org  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 12:17 IST  
Nmap scan report for scanme.nmap.org (45.33.32.156)  
Host is up (0.36s latency).  
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f  
Not shown: 992 closed tcp ports (reset)  
PORT      STATE      SERVICE  
22/tcp    open       ssh  
25/tcp    filtered  smtp  
80/tcp    open       http  
135/tcp   filtered  msrpc  
139/tcp   filtered  netbios-ssn  
445/tcp   filtered  microsoft-ds  
9929/tcp  open       nping-echo  
31337/tcp open       Elite  
  
Nmap done: 1 IP address (1 host up) scanned in 32.89 seconds  
└─(kali@kali)-[~]  
└─$
```

b) A SYN Flood is a type of Denial of Service (DoS) attack where:

- Attacker sends multiple SYN packets to the server.
- Server replies with SYN-ACK and waits for ACK that never comes.
- Server resources are held up → can crash or become unresponsive.

How to Prevent SYN Flood Attacks:

- **SYN Cookies** – Uses cryptographic hash to validate connections.
- **Timeout Adjustments** – Reduce time server waits for ACK.
- **Firewalls and IDS** – Block suspicious traffic.
- **Rate Limiting** – Control SYN requests per second.

Q2) Which Nmap command disables the host discovery and is used for port scanning only? Also, which Nmap command disables scanning and performs only host discovery?

Answer

When you run a normal Nmap scan, it first tries to detect if the host is up . Based on the response, it proceeds to port scanning.

Sometimes you may want to:

- Skip host discovery and directly scan ports
- Only discover live hosts without scanning any ports

1) Disable Host Discovery (for Port Scan Only)

Command:- `sudo nmap -Pn <target>`

```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ sudo nmap -Pn scanme.nmap.org  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 12:30 IST  
Nmap scan report for scanme.nmap.org (45.33.32.156)  
Host is up (0.31s latency).  
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f  
Not shown: 992 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
25/tcp    filtered smtp  
80/tcp    open  http  
135/tcp   filtered msrpc  
139/tcp   filtered netbios-ssn  
445/tcp   filtered microsoft-ds  
9929/tcp  open  nping-echo  
31337/tcp open  Elite  
Nmap done: 1 IP address (1 host up) scanned in 45.17 seconds  
(kali@kali)-[~]  
$
```

2) Only Perform Host Discovery (No Port Scan)

Command:- `sudo nmap -sn <target>`

```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ sudo nmap -sn scanme.nmap.org  
[sudo] password for kali:  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 13:16 IST  
Nmap scan report for scanme.nmap.org (45.33.32.156)  
Host is up (0.20s latency).  
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f  
Nmap done: 1 IP address (1 host up) scanned in 1.53 seconds  
(kali@kali)-[~]  
$
```

Q3) Differentiate between “full-open” and “half-open” scans. Also, what are the default scans with and without root privileges?

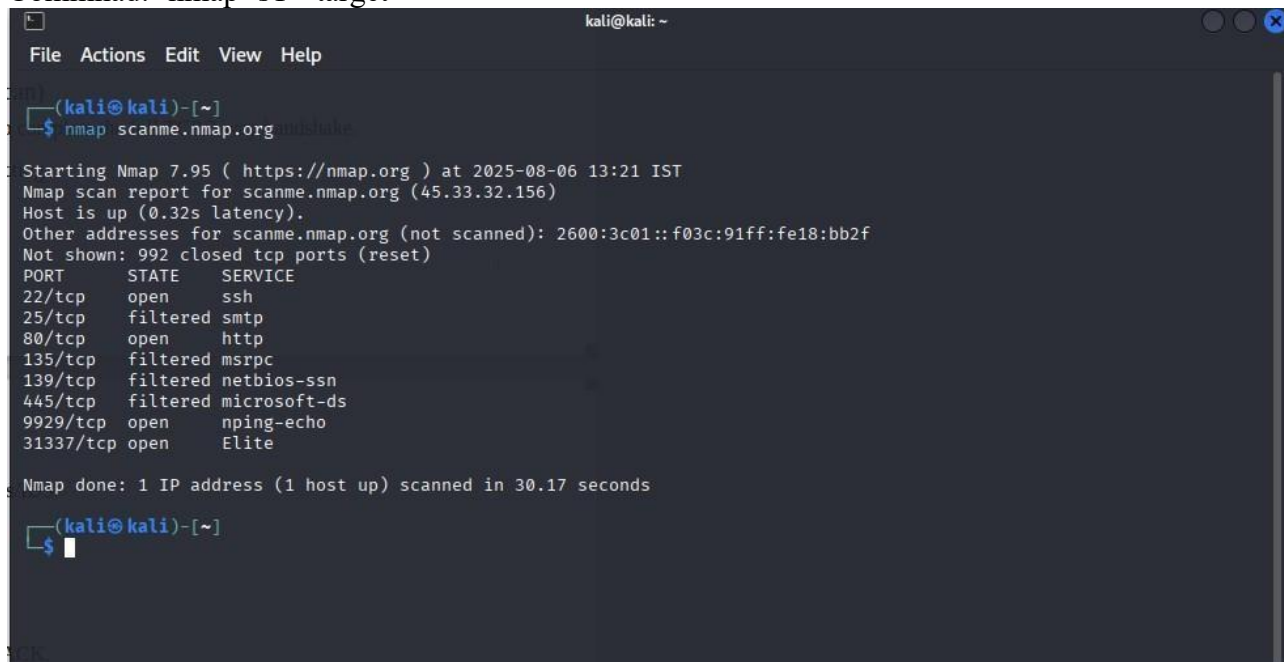
Answer

1. Full-Open Scan (TCP Connect Scan)

- Uses system's `connect ()` call to complete the full TCP 3-way handshake.
- Detects open ports by fully connecting.
- No need for root privileges.

- More easily detectable by firewalls/IDS.

Command:- `nmap -sT <target>`



```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ nmap scanme.nmap.org  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 13:21 IST  
Nmap scan report for scanme.nmap.org (45.33.32.156)  
Host is up (0.32s latency).  
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f  
Not shown: 992 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
25/tcp    filtered smtp  
80/tcp    open  http  
135/tcp   filtered msrpc  
139/tcp   filtered netbios-ssn  
445/tcp   filtered microsoft-ds  
9929/tcp  open  nping-echo  
31337/tcp open  Elite  
  
Nmap done: 1 IP address (1 host up) scanned in 30.17 seconds  
  
(kali@kali)-[~]  
$
```

2. Half-Open Scan (SYN Scan)

- Sends a SYN and waits for SYN-ACK.
- Doesn't complete the handshake (does NOT send ACK).
- Stealthier (harder to detect).
- Requires root privileges to send raw

packets. Command:- `sudo nmap -sS <target>`

```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ sudo nmap scanme.nmap.org  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 13:22 IST  
Nmap scan report for scanme.nmap.org (45.33.32.156)  
Host is up (0.42s latency).  
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f  
Not shown: 992 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
25/tcp    filtered smtp  
80/tcp    open  http  
135/tcp   filtered msrpc  
139/tcp   filtered netbios-ssn  
445/tcp   filtered microsoft-ds  
9929/tcp  open  nping-echo  
31337/tcp open  Elite  
Nmap done: 1 IP address (1 host up) scanned in 43.17 seconds  
(kali@kali)-[~]  
$
```

Q4)How do the following commands execute? How will it display the outputs?

`nmap -sC -sn vit.ac.in`

`nmap -sC -Pn Rediff.com`

`nmap -Pn -sn -sC google.com`

Answer

1. `nmap -sC -sn vit.ac.in`

- `-sC`: run default scripts
- `-sn`: do not scan ports, just ping the host

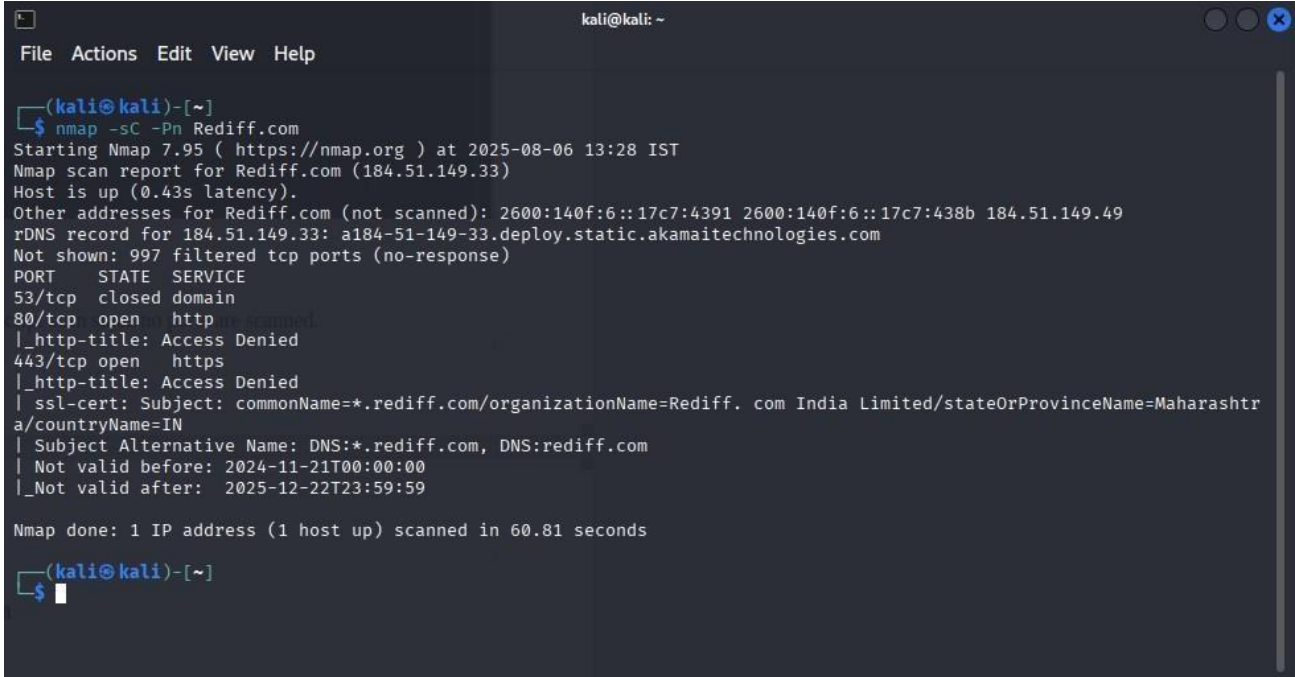
```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -sC -sn vit.ac.in  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 13:25 IST  
Nmap scan report for vit.ac.in (122.184.65.22)  
Host is up (0.058s latency).  
Other addresses for vit.ac.in (not scanned): 64:ff9b::7ab8:4116  
Nmap done: 1 IP address (1 host up) scanned in 11.58 seconds  
(kali@kali)-[~]  
$
```

Result:

This command will likely fail or skip the script scan since no ports are scanned.

2. `nmap -sC -Pn Rediff.com`

- `-sC`: run default scripts
- `-Pn`: skip ping, assume host is up



```
(kali@kali)-[~]
$ nmap -sC -Pn Rediff.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 13:28 IST
Nmap scan report for Rediff.com (184.51.149.33)
Host is up (0.43s latency).
Other addresses for Rediff.com (not scanned): 2600:140f:6::17c7:4391 2600:140f:6::17c7:438b 184.51.149.49
rDNS record for 184.51.149.33: a184-51-149-33.deploy.static.akamaitechnologies.com
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    closed domain
80/tcp    open  http
|_http-title: Access Denied
443/tcp    open  https
|_http-title: Access Denied
|_ssl-cert: Subject: commonName=*.rediff.com/organizationName=Rediff. com India Limited/stateOrProvinceName=Maharashtr
a/countryName=IN
| Subject Alternative Name: DNS:*.rediff.com, DNS:rediff.com
| Not valid before: 2024-11-21T00:00:00
|_Not valid after: 2025-12-22T23:59:59

Nmap done: 1 IP address (1 host up) scanned in 60.81 seconds

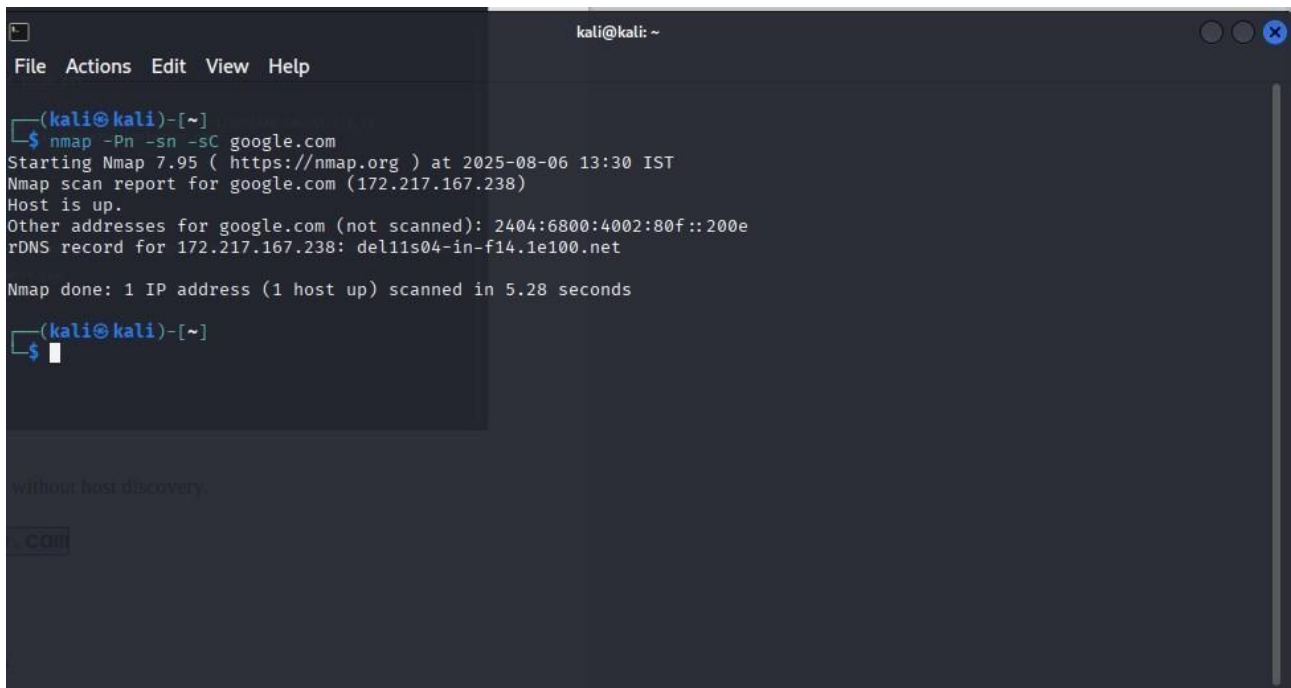
(kali@kali)-[~]
$
```

Result: Performs full port scan with scripts without host discovery.

3. `nmap -Pn -sn -sC google.com`

This is a conflicting command:

- `-sn`: disables port scan
- `-sC`: needs ports open to run scripts



```
(kali@kali)-[~]
$ nmap -Pn -sn -sC google.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 13:30 IST
Nmap scan report for google.com (172.217.167.238)
Host is up.
Other addresses for google.com (not scanned): 2404:6800:4002:80f::200e
rDNS record for 172.217.167.238: del11s04-in-f14.1e100.net
Nmap done: 1 IP address (1 host up) scanned in 5.28 seconds

(kali@kali)-[~]
$
```

Q5)What is Ping-of-Death? How will you perform a Ping-of-Death attack using the command prompt as a batch file?

Answer

Ping of Death is a **Denial of Service (DoS)** attack where:

- An attacker sends malformed or oversized ping (ICMP) packets to a target.
- Standard ping packet size = 64 bytes (up to 65,535 bytes including headers).
- PoD packets exceed allowed size causing buffer overflow on vulnerable systems.
- This can crash, freeze, or reboot the system.
- Most modern systems are patched against this, but older OS versions were vulnerable.

Steps to Create .bat File:

1. Open Notepad on Windows.
2. Paste the code above.
3. Replace <target-ip> with any dummy IP or test VM like 127.0.0.1
4. Save as: ping_of_death.bat
5. Right-click → Run as Administrator (on Windows machine)

Simulation on Kali

1. Basic Command (send oversized ping)

ping -s 65500 <target-ip>

-s 65500: sets the payload size to 65,500 bytes

2. Send continuously (like a loop)

Create PoD script:

```
nano ping_of_death.sh
```

Paste:

```
#!/bin/bash
while true
do
    ping -s 65500 127.0.0.1
done
```

Q6) Distinguish between Ping Flood vs. SYN Flood.

Answer

Ping Flood Attack (ICMP Flood)

A Ping Flood attack uses the `ping` command to send a huge volume of ICMP Echo Request packets to a target system, attempting to overwhelm its network bandwidth or processing capacity.

Command:- `ping -f <target-ip>`

`-f` is flood mode, sends packets as fast as possible

Goal:

- Exhaust network bandwidth
- Consume CPU processing power on target by forcing it to reply to each ping

Countermeasures:

- Block ICMP at firewall
- Rate-limit ICMP requests
- Use IDS/IPS to detect flood patterns

SYN Flood Attack (TCP SYN Attack)

A SYN Flood sends many TCP SYN packets to the target server with spoofed IPs or without completing the handshake, causing the server to hold resources waiting for completion.

Goal:

- Exploit TCP's 3-way handshake
- Exhaust connection table / memory of server
- Leads to Denial of Service

Command:- `sudo hping3 -S -p 80 --flood <target-ip>`

-S: sends SYN flag

- --flood: sends packets as fast as possible
- -p 80: targets port 80

Countermeasures:

- Enable SYN Cookies
- Firewall filtering
- Reduce connection timeout
- Use IDS/IPS (e.g., Snort)

Feature	Ping Flood	SYN Flood
Protocol	ICMP	TCP
Tool	ping	hping3, raw TCP
Attack vector	Echo Request (ICMP)	SYN Packet (TCP handshake initiation)
Goal	Bandwidth exhaustion	Resource exhaustion (connection queue)
Easily detectable?	Yes	Less so (stealthier)
Common countermeasures	ICMP blocking, rate limiting	SYN cookies, firewalls, timeouts

Q7)What does a Ping sweep do? How will you run a ping sweep using the Nmap tool? Display the output as a screenshot.

Answer

A Ping Sweep is a network reconnaissance technique used to discover active (live) hosts in a subnet or IP range.

- It sends ICMP Echo Requests (ping) to a range of IPs.
- Hosts that respond are considered “up” or reachable.
- It's typically the first step in a network scan.

Command:- sudo nmap -sn <target-subnet>

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ sudo nmap -sn 192.168.1.0/24  
[sudo] password for kali:  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 20:17:15T  
Nmap scan report for 192.168.1.0  
Host is up (0.125s latency).  
Nmap scan report for 192.168.1.1  
Host is up (0.425s latency).  
Nmap scan report for 192.168.1.2  
Host is up (0.425s latency).  
Nmap scan report for 192.168.1.3  
Host is up (0.125s latency).  
Nmap scan report for 192.168.1.4  
Host is up (0.325s latency).  
Nmap scan report for 192.168.1.5  
Host is up (0.325s latency).  
Nmap scan report for 192.168.1.6  
Host is up (0.100s latency).  
Nmap scan report for 192.168.1.7  
Host is up (0.100s latency).  
Nmap scan report for 192.168.1.8  
Host is up (0.100s latency).  
Nmap scan report for 192.168.1.9  
Host is up (0.25s latency).  
Nmap scan report for 192.168.1.10  
Host is up (0.25s latency).  
Nmap scan report for 192.168.1.11  
Host is up (0.25s latency).  
Nmap scan report for 192.168.1.12  
Host is up (0.080s latency).  
Nmap scan report for 192.168.1.13  
Host is up (0.25s latency).  
Nmap scan report for 192.168.1.14  
Host is up (0.080s latency).  
Nmap scan report for 192.168.1.15  
Host is up (0.080s latency).  
Nmap scan report for 192.168.1.16  
Host is up (0.25s latency).  
Nmap scan report for 192.168.1.17  
Host is up (0.25s latency).  
Nmap scan report for 192.168.1.18  
Host is up (0.080s latency).  
Nmap scan report for 192.168.1.19  
Host is up (0.080s latency).  
Nmap scan report for 192.168.1.20  
Host is up (0.25s latency).  
Nmap scan report for 192.168.1.21  
Host is up (0.25s latency).  
Nmap scan report for 192.168.1.22  
Host is up (0.25s latency).  
Nmap scan report for 192.168.1.23  
Host is up (0.080s latency).  
Nmap scan report for 192.168.1.24  
Host is up (0.080s latency).  
Nmap scan report for 192.168.1.25  
Host is up (0.25s latency).  
Nmap scan report for 192.168.1.26  
Host is up (0.25s latency).  
Nmap scan report for 192.168.1.27
```

Feature	Ping Flood	SYN Flood
Protocol	ICMP	TCP
Goal	Deny	Deny (e.g., raw TCP)
Attack vector	ICMP Echo (ping)	SYN Packet (TCP handshake initiation)
Goal	Bandwidth exhaustion	Resource exhaustion (connection queue)
Easily detected?	Yes	Less so (visibility)
Common countermeasures	ICMP blocking, rate limiting	SYN cookies, firewalls, timeouts

Q: What does a Ping sweep do? (How will you run a ping sweep using the Nmap tool? Display the output as a screenshot.)

Answer:

A Ping Sweep is a network reconnaissance technique used to discover active (live) hosts in a subnet or IP range.

- It sends ICMP Echo Requests (ping) to a range of IPs.
- Hosts that respond are considered "up" or available.
- It's typically the first step in a network scan.

Example: sudo nmap -sn 192.168.1.0/24

```
kali@kali: ~  
File Actions Edit View Help  
Nmap scan report for 192.168.1.244  
Host is up (0.125s latency).  
Nmap scan report for 192.168.1.245  
Host is up (0.028s latency).  
Nmap scan report for 192.168.1.246  
Host is up (0.12s latency).  
Nmap scan report for 192.168.1.247  
Host is up (0.34s latency).  
Nmap scan report for 192.168.1.248  
Host is up (0.34s latency).  
Nmap scan report for 192.168.1.249  
Host is up (0.14s latency).  
Nmap scan report for 192.168.1.250  
Host is up (0.24s latency).  
Nmap scan report for 192.168.1.251  
Host is up (0.12s latency).  
Nmap scan report for 192.168.1.252  
Host is up (0.12s latency).  
Nmap scan report for 192.168.1.253  
Host is up (0.12s latency).  
Nmap scan report for 192.168.1.254  
Host is up (0.12s latency).  
Nmap scan report for 192.168.1.255  
Host is up (0.12s latency).  
Nmap done: 256 IP addresses (256 hosts up) scanned in 88.39 seconds  
kali@kali:~$
```

```
kali@kali: ~  
File Actions Edit View Help  
Host is up (0.12s latency).  
Nmap scan report for 192.168.1.254  
Host is up (0.12s latency).  
Nmap scan report for 192.168.1.255  
Host is up (0.12s latency).  
Nmap done: 256 IP addresses (256 hosts up) scanned in 88.39 seconds  
  
(kali@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc fq_codel state DOWN group default qlen 1000  
    link/ether 08:8f:c3:62:7c:13 brd ff:ff:ff:ff:ff:ff  
3: wlan0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000  
    link/ether 70:a8:d3:1e:d8:fe brd ff:ff:ff:ff:ff:ff  
    inet 10.80.79.223/24 brd 10.80.79.255 scope global dynamic noprefixroute wlan0  
        valid_lft 2683sec preferred_lft 2683sec  
    inet6 2409:40f4:1f:a6d9:2cb0:196f:2466:dee8/64 scope global dynamic noprefixroute  
        valid_lft 6290sec preferred_lft 6290sec  
    inet6 fe80::4eaa:ab32:d9c:b15b/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
  
(kali@kali)-[~]  
$
```

Q8)Using the Windows batch file, execute the Ping Sweep scan from the command prompt.

Answer

Steps for Windows

1) Create a Batch file

```
@echo off  
for /L %%i in (1,1,10) do (  
    ping -n 1 192.168.1.%%i | find "TTL=" && echo Host 192.168.1.%%i is UP  
)  
pause
```

```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ nano ping_sweep.sh  
  
(kali@kali)-[~]  
$ chmod +x ping_sweep.sh  
  
(kali@kali)-[~]  
$ ./ping_sweep.sh  
  
(kali@kali)-[~]  
$ nano ping_sweep.sh  
  
(kali@kali)-[~]  
$  
  
(kali@kali)-[~]  
$ chmod +x ping_sweep.sh  
./ping_sweep.sh  
  
64 bytes from 10.80.79.223: icmp_seq=1 ttl=64 time=0.014 ms  
Host 10.80.79.223 is UP  
  
(kali@kali)-[~]  
$
```

Steps to Use:

1. Open **Notepad** on a Windows machine
2. Paste the above code
3. Save the file
4. Run the file

Expected Output Windows

Pinging 192.168.1.1 with 32 bytes of data:

Reply from 192.168.1.1: bytes=32 time<1ms TTL=64

Host 192.168.1.1 is UP

Pinging 192.168.1.2 with 32 bytes of data:

Request timed out.

Q9) The_____script is used to gather detailed information about directories, files, and other details from web servers. [PROVIDE THE SCREENSHOT OF THE OUTPUT]

Answer

Command:- http-enum

sudo nmap --script http-enum -p 80 <target-ip>

It uses a wordlist to brute-force common directory names on a web server.

- Helps identify hidden paths like:
 - /admin/
 - /login/
 - /uploads/
- It's used in web reconnaissance to fingerprint accessible resources.

```
kali@kali: ~  
File Actions Edit View Help  
Fetched 3,031 B in 1s (2,039 B/s)  
5 packages can be upgraded. Run 'apt list --upgradable' to see them.  
apache2 is already the newest version (2.4.65-2).  
apache2 set to manually installed.  
Summary:  
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 5  
  
(kali@kali)-[~]  
$ sudo ss -tuln | grep :80  
  
tcp    LISTEN 0      511      *:80      *:*  
  
(kali@kali)-[~]  
$ sudo nmap --script http-enum -p 80 127.0.0.1  
  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 20:38 IST  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.000071s latency).  
  
PORT      STATE SERVICE  
80/tcp    open  http  
| http-enum:  
|_ /server-status/: Potentially interesting folder  
  
Nmap done: 1 IP address (1 host up) scanned in 0.42 seconds  
  
(kali@kali)-[~]  
$
```

Q10) Which Nmap command will enumerate the web server directories? [Provide the screenshot of the output]

Answer

Command:- `sudo nmap --script http-enum -p 80 <target-ip>`
`sudo nmap --script http-enum -p 80 127.0.0.1`

The script `http-enum` uses a built-in wordlist to brute-force and identify common directories such as:

- `/admin/`
 - `/login/`
 - `/server-status/`
 - `/uploads/`
- It only works if port 80 (or 443 for HTTPS with `ssl-enum`) is open and accessible.

```
kali@kali: ~  
File Actions Edit View Help  
Fetched 3,031 B in 1s (2,039 B/s)  
5 packages can be upgraded. Run 'apt list --upgradable' to see them.  
apache2 is already the newest version (2.4.65-2).  
apache2 set to manually installed.  
Summary:  
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 5  
  
(kali@kali)-[~]  
$ sudo ss -tln | grep :80  
  
tcp    LISTEN 0      511             *:80           *:.*  
  
(kali@kali)-[~]  
$ sudo nmap --script http-enum -p 80 127.0.0.1  
  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 20:38 IST  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.000071s latency).  
PORT      STATE SERVICE  
80/tcp    open  http  
|_ http-enum:  
|_ /server-status/: Potentially interesting folder  
  
Nmap done: 1 IP address (1 host up) scanned in 0.42 seconds  
  
(kali@kali)-[~]  
$
```

K

Q11) For which Nmap command will you get the result as: "|_ http-malware-host: Host appears to be clean" Perform the scan for your machine's IP address.

Answer

The Nmap NSE script `http-malware-host` checks whether a web server is hosting malware, according to public blacklists.

Command:- `sudo nmap --script http-malware-host -p 80 <your-ip>`

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ sudo nmap --script http-malware-host -p 80 127.0.0.1  
  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 20:48 IST  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.000073s latency).  
  
PORT      STATE SERVICE  
80/tcp    open  http  
|_ http-malware-host: Host appears to be clean  
  
Nmap done: 1 IP address (1 host up) scanned in 0.16 seconds  
  
(kali@kali)-[~]  
$
```

Q12) Which Nmap command will check for the SambaCry vulnerability?
[Provide the screenshots of the output received]

Answer

SambaCry (CVE-2017-7494) is a critical remote code execution vulnerability in Samba servers.

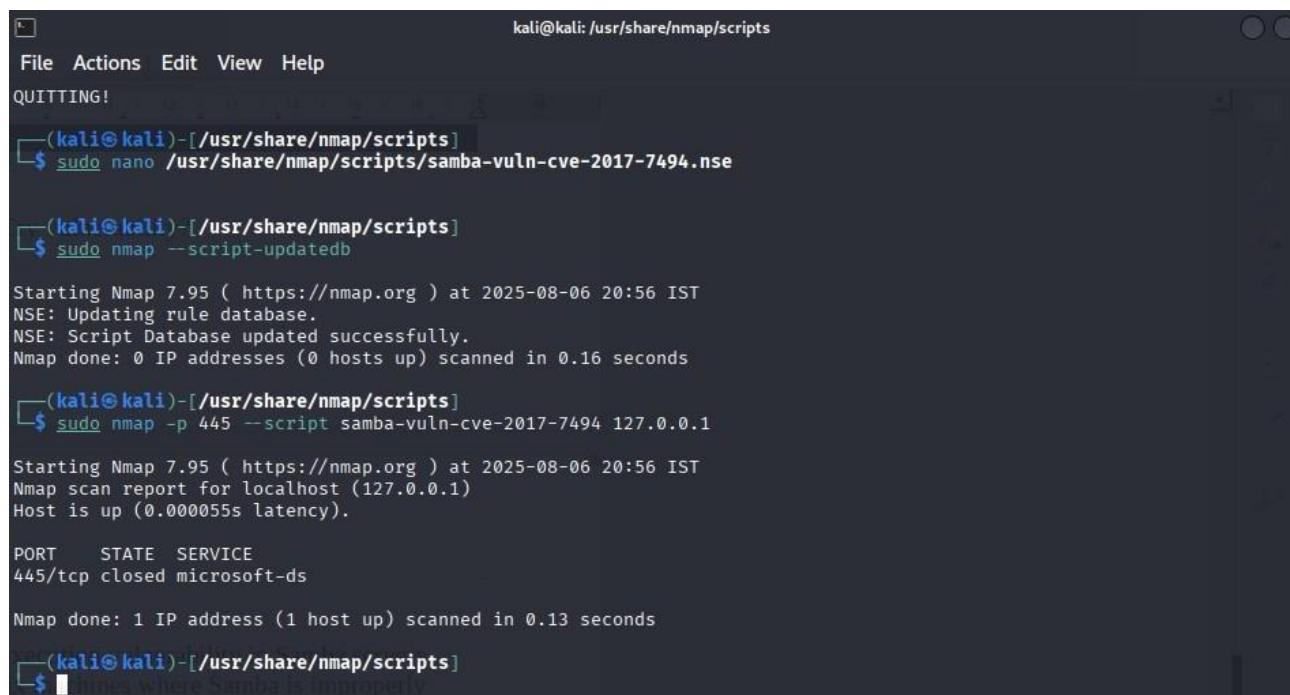
- It allows attackers to execute code on Linux/Unix machines where Samba is improperly configured.

Nmap Command Used:- samba-vuln-cve-2017-7494

sudo nmap -p 445 --script samba-vuln-cve-2017-7494 <target-ip>

-p 445 = Port used by Samba/SMB

--script samba-vuln-cve-2017-7494 = NSE script to check for vulnerability



```
kali@kali: /usr/share/nmap/scripts
File Actions Edit View Help
QUITTING!
(kali@kali)-[/usr/share/nmap/scripts]
$ sudo nano /usr/share/nmap/scripts/samba-vuln-cve-2017-7494.nse
(kali@kali)-[/usr/share/nmap/scripts]
$ sudo nmap --script-updatedb
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 20:56 IST
NSE: Updating rule database.
NSE: Script Database updated successfully.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.16 seconds
(kali@kali)-[/usr/share/nmap/scripts]
$ sudo nmap -p 445 --script samba-vuln-cve-2017-7494 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 20:56 IST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000055s latency).

PORT      STATE SERVICE
445/tcp   closed microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 0.13 seconds
(kali@kali)-[/usr/share/nmap/scripts]
$
```

Q13)What single-line command is used to scan port 80,443,8080?

[PROVIDE THE SCREENSHOTS OF ALL THE COMMANDS]

Answer

Command:- sudo nmap -p 80,443,8080 <target-ip>


```
kali@kali: /usr/share/nmap/scripts

File Actions Edit View Help

(kali@kali)-[/usr/share/nmap/scripts]
$ sudo nmap -p 80,443,8080 127.0.0.1

Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 20:58 IST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000052s latency).

PORT      STATE SERVICE
80/tcp    open  http
443/tcp   closed https
8080/tcp   closed http-proxy

Nmap done: 1 IP address (1 host up) scanned in 0.08 seconds

(kali@kali)-[/usr/share/nmap/scripts]
$
```

0

```
kali@kali: /usr/share/nmap/scripts

File Actions Edit View Help

(kali@kali)-[/usr/share/nmap/scripts]
$ sudo nmap -p 80,443,8080 scanme.nmap.org

Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 20:59 IST
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.14s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f

PORT      STATE SERVICE
80/tcp    open  http
443/tcp   closed https
8080/tcp   closed http-proxy

Nmap done: 1 IP address (1 host up) scanned in 1.33 seconds

(kali@kali)-[/usr/share/nmap/scripts]
$
```

0

Q14) Which nmap command won't work? [PROVIDE THE SCREENSHOTS OF ALL THE COMMANDS]

nmap 192.168.1.100-130

nmap -host -p 443 192.168.1.101

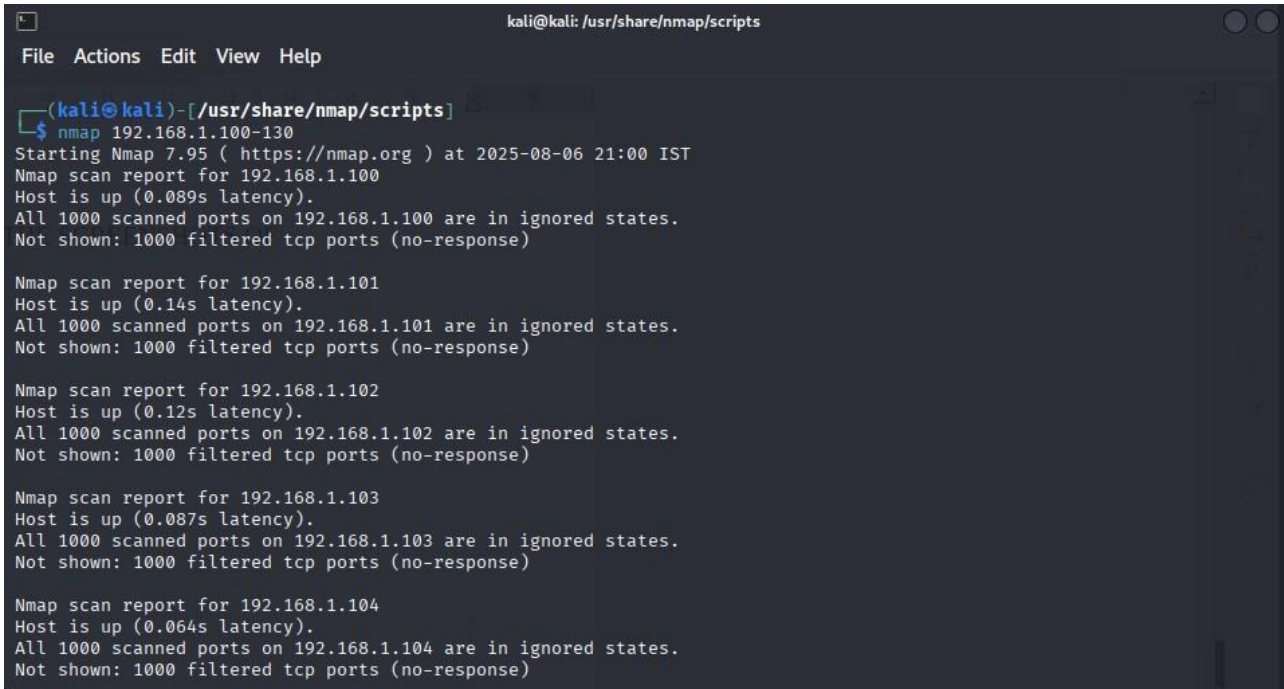
nmap -iL hosts.txt

nmap 192.168.0.*

Answer

`nmap 192.168.1.100-130`

- Correctly Works
- Scans IPs from 192.168.1.100 to 192.168.1.130



```
kali@kali: /usr/share/nmap/scripts
File Actions Edit View Help

(kali@kali)-[/usr/share/nmap/scripts]
$ nmap 192.168.1.100-130
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 21:00 IST
Nmap scan report for 192.168.1.100
Host is up (0.089s latency).
All 1000 scanned ports on 192.168.1.100 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.1.101
Host is up (0.14s latency).
All 1000 scanned ports on 192.168.1.101 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.1.102
Host is up (0.12s latency).
All 1000 scanned ports on 192.168.1.102 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.1.103
Host is up (0.087s latency).
All 1000 scanned ports on 192.168.1.103 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.1.104
Host is up (0.064s latency).
All 1000 scanned ports on 192.168.1.104 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
```

`nmap -host -p 443 192.168.1.101`

- Invalid option: `-host` is not a real Nmap flag
- This will fail with an error

```
kali@kali: /usr/share/nmap/scripts
File Actions Edit View Help

(kali@kali)-[/usr/share/nmap/scripts]
$ nmap -host -p 443 192.168.1.101
Bogus --host-timeout argument specified
QUITTING!
machine's IP address.
(kali@kali)-[/usr/share/nmap/scripts]
$
```

0

nmap -iL hosts.txt

- Scans IPs listed in a file called `hosts.txt`
- Valid and commonly used

```
kali@kali: /usr/share/nmap/scripts
File Actions Edit View Help

(kali@kali)-[/usr/share/nmap/scripts]
$ nmap -iL hosts.txt
Failed to open input file hosts.txt for reading: No such file or directory (2)
(kali@kali)-[/usr/share/nmap/scripts]
$
```

nmap 192.168.0.*

- Wildcard expansion handled by the shell
- Scans all IPs from `192.168.0.1` to `192.168.0.254`

```
File Actions Edit View Help
kali@kali: /usr/share/nmap/scripts
└─$ nmap 192.168.0.0
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-06 21:07 IST
Nmap scan report for 192.168.0.0
Host is up (0.0009s latency).
All 1000 scanned ports on 192.168.0.0 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.1
Host is up (0.0485s latency).
All 1000 scanned ports on 192.168.0.1 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.2
Host is up (0.0945s latency).
All 1000 scanned ports on 192.168.0.2 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.3
Host is up (0.0645s latency).
All 1000 scanned ports on 192.168.0.3 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.4
Host is up (0.0565s latency).
All 1000 scanned ports on 192.168.0.4 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.5
Host is up (0.0715s latency).
All 1000 scanned ports on 192.168.0.5 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.6
Host is up (0.0875s latency).
All 1000 scanned ports on 192.168.0.6 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.7
Host is up (0.0535s latency).
All 1000 scanned ports on 192.168.0.7 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.8
Host is up (0.0565s latency).
All 1000 scanned ports on 192.168.0.8 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.9
Host is up (0.0785s latency).
All 1000 scanned ports on 192.168.0.9 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.10
Host is up (0.0645s latency).
All 1000 scanned ports on 192.168.0.10 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap scan report for 192.168.0.11
Host is up (0.0675s latency).
```